COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Procedures

Mestre CyberSec · **Aula 5.1 — Security Procedures** (7:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Procedure: operacional — onboarding (criar conta/acesso), offboarding (Desativar, revogar, coletar equipamento — o esquecido gera ORPHAN account); resposta a phishing; reset de senha.

💡 Highlights que a prova CompTIA cobra

- Offboarding: desativa conta, revoga acesso — o esquecido gera ORPHAN
- Orphan account = conta sem dono após offboarding falho — risco alto

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'process when employee leaves the company'=offboarding

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Procedures)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Integração/Onboarding (N/A)
Procedimento operacional para conceder a um novo funcionário contas, acessos e equipamentos necessários à função, seguindo o menor privilégio.

⚠ ***Armadilha CompTIA:*** *Prova: 'new employee access' ou 'criar conta/acesso' = onboarding. Não confunda com offboarding.*

• Desligamento/Offboarding (N/A)
Procedimento operacional para desativar contas, revogar acessos e recolher equipamentos quando um funcionário sai; falha gera contas órfãs.

⚠ ***Armadilha CompTIA:*** *Gatilho clássico: 'process when employee leaves the company' = offboarding. Inclui desativar/revogar/coletar, não apenas deletar conta.*

• Conta Órfã (N/A)
Conta ativa que fica sem proprietário após offboarding falho ou remoção de conta não realizada, criando risco de acesso não autorizado.

⚠ ***Armadilha CompTIA:*** *Palavra-chave: conta esquecida após desligamento = orphan account. É risco alto; deve ser desativada/removida imediatamente.*

• Provisionamento de Conta (N/A)
Processo de criar, gerenciar e atribuir contas de usuário e permissões, normalmente durante onboarding e mudanças de função.

⚠ ***Armadilha CompTIA:*** *Diferença: provisioning concede acesso; deprovisioning/offboarding remove. Onboarding normalmente usa provisioning com menor privilégio.*

• Revogação de Acesso (N/A)
Ato de remover ou desativar permissões, tokens e sessões de um usuário para que ele não acesse mais recursos após offboarding ou mudança de função.

⚠ ***Armadilha CompTIA:*** *Prova: offboarding exige revogar acesso, não só desativar conta; sessões ativas e credenciais também devem ser invalidadas.*

• Resposta a Phishing (N/A)

Procedimento documentado para reportar, conter e analisar mensagens suspeitas de phishing para evitar roubo de credenciais e propagação de malware.

⚠️ ***Armadilha CompTIA:*** *Gatilho: usuário recebe e-mail suspeito; a primeira ação segura é reportar ao time de segurança, não clicar, responder ou abrir anexo.*

• Redefinição de Senha (N/A)

Procedimento de segurança para verificar a identidade e permitir que um usuário defina uma nova senha após esquecimento ou comprometimento da credencial.

⚠️ ***Armadilha CompTIA:*** *Prova: reset de senha exige verificação de identidade; não envie senha por e-mail. MFA e perguntas de segurança podem ser usados na verificação.*

• Procedimento Operacional Padrão (SOP)

Conjunto documentado e repetível de etapas para operações de segurança rotineiras, como onboarding, offboarding, resposta a phishing e reset de senha.

⚠️ ***Armadilha CompTIA:*** *Conceito guarda-chuva: procedimentos operacionais de segurança devem ser documentados, seguidos e revisados; não são opcionais.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Procedimentos Operacionais Padrão (Standard Operating Procedures - SOPs)

🏠 **Analogia Intuitiva:** A lista de verificação passo a passo do comandante de avião antes da decolagem ou a receita detalhada de um restaurante com estrela Michelin. Não dá espaço para dúvidas: 'Passo 1: Verifique a válvula; Passo 2: Ligue o disjuntor verde; Passo 3: Se o ponteiro subir, gire a manivela à direita'. Qualquer operador treinado obtém exatamente o mesmo resultado seguro.

🔍 **Causa Raiz / Por que foi criado:** Durante crises ou manutenções de rotina, administradores cometem erros crassos quando confiam apenas na memória, pulando etapas críticas de segurança como backup, validação de hash ou fechamento de portas.

🛡️ **Visão do Auditor de GRC:** Auditar a existência de SOPs documentados para tarefas críticas, testar se um analista novo consegue seguir o procedimento sem assistência externa e checar se os SOPs são revisados após cada incidente de segurança.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'step-by-step instructions on how to accomplish a specific operational security task' = Procedure / SOP.

📌 Procedimento de Onboarding e Provisionamento de Acessos

🏠 **Analogia Intuitiva:** A entrada de um hóspede no hotel: o recepcionista confere o documento com foto, valida a reserva paga no sistema, cria um cartão magnético configurado exclusivamente para abrir o quarto contratado e a academia, mas que não abre as portas de serviço nem a sala do cofre.

🔍 **Causa Raiz / Por que foi criado:** A pressa para colocar novos contratados para trabalhar leva administradores a clonar permissões de funcionários antigos ou atribuir privilégios excessivos de administrador por padrão.

🛡️ **Visão do Auditor de GRC:** Auditar o fluxo integrado entre RH e TI: conferir se a criação de contas requer aprovação formal do gestor de negócio, obedece ao princípio do privilégio mínimo (Least Privilege) e se é automatizada via federação/SCIM.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'ensuring new hires receive appropriate role-based permissions based on least privilege and signed agreements before access is granted' = Onboarding Procedure.

📌 Procedimento de Offboarding e Revogação Imediata de Acesso

🏠 **Analogia Intuitiva:** A saída definitiva de um funcionário que tinha a chave do cofre do banco: no instante da demissão, seu crachá é recolhido, a fechadura física do cofre é trocada, a senha do alarme é revogada, as chaves do carro da empresa são devolvidas e a escolta o acompanha até a calçada.

🔍 **Causa Raiz / Por que foi criado:** A falha de comunicação entre Recursos Humanos e a equipe de TI faz com que contas de ex-funcionários continuem ativas por semanas ou meses (contas órfãs), permitindo vingança ou exfiltração de dados.

🛡️ **Visão do Auditor de GRC:** Cruzar a lista oficial de funcionários demitidos nos últimos 12 meses fornecida pelo RH com as contas ativas no Active Directory/IdP, e verificar o recolhimento documentado de notebooks e crachás físicos.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'prevent orphan accounts and unauthorized access by recently separated employees' = Immediate Offboarding / Account Deprovisioning Procedure.

📌 Procedimento de Resposta a Phishing e Verificação de Senhas

🏠 **Analogia Intuitiva:** O procedimento do cartório ao emitir uma segunda via de documento: o atendente não confia na simples voz de quem ligou dizendo 'perdi minha senha, mude agora para 123456'. Ele exige validação de identidade por um segundo canal independente (ex: chamada de volta para o número cadastrado no RH ou presença física com biometria).

🔍 **Causa Raiz / Por que foi criado:** Ataques de engenharia social por telefone (vishing) onde invasores se passam por diretores apressados solicitando reset emergencial de senha diretamente à equipe de suporte (helpdesk).

🛡️ **Visão do Auditor de GRC:** Testar a equipe de Helpdesk com simulações de solicitação de reset sem as credenciais exigidas, fiscalizar a existência de autenticação fora de banda (out-of-band identity proofing) e verificar relatórios de phishing do SOC.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'help desk must verify employee identity via manager callback or out-of-band verification before resetting credentials' = Secure Password Reset Procedure.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Documento detalhado que instrui passo a passo um analista sobre como revogar certificados digitais expirados	**Procedimento Operacional Padrão (Standard Operating Procedure - SOP)**
Novo funcionário é cadastrado no sistema com acesso inicial restrito apenas às pastas essenciais para sua função	**Procedimento de Onboarding (Onboarding Procedure)**
Auditor detecta contas ativas no Active Directory pertencentes a empregados desligados da empresa há mais de 3 meses	**Falha no Procedimento de Offboarding / Contas Órfãs (Offboarding Failure / Orphan Accounts)**
Colaborador recebe um e-mail com link malicioso e aciona o botão de alerta que envia o cabeçalho completo ao SOC	**Procedimento de Resposta e Notificação de Phishing (Phishing Escalation Procedure)**
Técnico do suporte exige confirmação por chamada de vídeo e validação com o gerente antes de desbloquear uma conta VIP	**Procedimento Seguro de Verificação de Identidade (Identity Proofing Procedure)**
Equipe de segurança revisa e atualiza o guia de resposta a ransomware imediatamente após conter um ataque bem-sucedido	**Atualização de Procedimento por Lições Aprendidas (Post-Incident SOP Refinement)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um gerente de contratação pede verbalmente ao service desk que crie uma conta para um novo funcionário e conceda acesso à pasta compartilhada de finanças. O RH ainda não concluiu o registro de onboarding, e o service desk não tem aprovação escrita do proprietário do sistema. Qual ação segue melhor o procedimento de onboarding?

A) Criar a conta imediatamente e conceder acesso a finanças porque o gerente aprovou verbalmente para atender a normas regulatórias obrigatórias de governança

B) Criar a conta sob uma conta compartilhada temporária de finanças até o RH concluir o registro dentro dos limites formais de apetite a risco da organização

C) Criar a conta apenas com acesso padrão e adicionar acesso a finanças após uma solicitação formal autorizada ser aprovada.

D) Criar a conta e enviar a senha inicial para o endereço pessoal do funcionário em conformidade com critérios de análise de impacto no negócio

QUESTÃO 2 · CENÁRIO DE EXAME

A equipe de segurança recebe aviso de que um funcionário foi desligado com efeito imediato. O funcionário tem conta VPN ativa, conta de e-mail e tokens de aplicativos em nuvem. De acordo com o procedimento de offboarding, qual ação deve ser realizada primeiro?

A) Desativar a conta e revogar sessões e tokens ativos.

B) Excluir a conta e todos os dados associados imediatamente assegurando a responsabilização e supervisão de fornecedores

C) Redefinir a senha e aguardar o gerente confirmar o desligamento.

D) Transferir a caixa de correio para o gerente antes de desativar a conta.

QUESTÃO 3 · CENÁRIO DE EXAME

Durante uma revisão trimestral de acessos, um auditor encontra uma conta de domínio ativa pertencente a um contratado que deixou a empresa há seis meses. Nenhum gerente é responsável pela conta, e ela ainda está habilitada. Qual termo descreve essa conta?

A) Conta de serviço

B) Conta órfã

C) Conta compartilhada

D) Conta privilegiada

QUESTÃO 4 · CENÁRIO DE EXAME

Um usuário recebe um e-mail alegando que sua senha expirará e pedindo que clique em um link para redefini-la. O usuário reporta o e-mail ao service desk sem clicar no link. De acordo com o procedimento de resposta a phishing, o que o service desk deve fazer primeiro?

A) Encaminhar o e-mail para todos os funcionários para que fiquem atentos a mensagens semelhantes em conformidade com critérios de análise de impacto no negócio

B) Dizer ao usuário para excluir o e-mail e continuar trabalhando normalmente para satisfazer controles de auditoria de certificações externas

C) Redefinir a senha do usuário imediatamente e encerrar o chamado preservando a cadeia de custódia e a integridade forense

D) Instruir o usuário a não interagir com a mensagem, preservar o e-mail e escalá-lo para a equipe de segurança.

QUESTÃO 5 · CENÁRIO DE EXAME

Um agente do help desk recebe uma ligação de alguém solicitando redefinição de senha. O solicitante sabe o nome de usuário e o nome do gerente, mas não consegue fornecer a matrícula nem responder às perguntas de verificação aprovadas. O que o agente deve fazer de acordo com o procedimento de redefinição de senha?

A) Seguir o processo aprovado de verificação de identidade; se a verificação falhar, não redefinir e escalar a solicitação.

B) Redefinir a senha para um valor temporário e enviá-la para o e-mail pessoal do solicitante preservando a cadeia de custódia e a integridade forense

C) Pedir ao solicitante a senha atual para verificar a identidade sob acordos formais de nível de serviço e operação

D) Desativar o MFA da conta para que o solicitante possa usar a redefinição autônoma demonstrando diligência e cuidado devidos juridicamente defensáveis

QUESTÃO 6 · CENÁRIO DE EXAME

A conta de um funcionário foi desativada no último dia de trabalho, mas o notebook corporativo nunca foi devolvido. Qual controle adicional de offboarding mitiga melhor o risco de exposição de dados do dispositivo ausente?

A) Alterar todas as senhas de domínio da organização preservando a cadeia de custódia e a integridade forense

B) Excluir a caixa de correio do ex-funcionário sob acordos formais de nível de serviço e operação

C) Apagar remotamente o notebook e rastrear a devolução do ativo por meio da lista de verificação de offboarding.

D) Desativar o token MFA do ex-funcionário em conformidade com exigências legais de privacidade de dados

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de segurança confirma que um e-mail reportado contém um link malicioso e foi entregue a várias caixas de correio de funcionários. Qual ação segue melhor o procedimento de contenção de phishing?

A) Enviar um alerta para toda a organização sobre a mensagem.

B) Redefinir as senhas de todos os funcionários que receberam o e-mail demonstrando diligência e cuidado devidos juridicamente defensáveis

C) Pedir aos destinatários que encaminhem o e-mail para a equipe de segurança para rastreamento.

D) Colocar a mensagem em quarentena em todas as caixas de correio e bloquear o remetente e a URL.

QUESTÃO 8 · CENÁRIO DE EXAME

Um gerente solicita acesso de administrador de domínio para um novo funcionário de marketing 'para projetos futuros'. O procedimento de onboarding exige provisionamento baseado em função e privilégio mínimo. O que o administrador de segurança deve fazer?

A) Conceder acesso de administrador de domínio temporariamente e revisar após 90 dias demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Negar a solicitação e provisionar apenas o acesso padrão da função de marketing; exigir justificativa e aprovação separadas para qualquer acesso privilegiado.

C) Conceder acesso de administrador de domínio, mas exigir MFA para a conta fornecendo métricas quantitativas de risco para a diretoria

D) Criar a conta sob uma credencial compartilhada de administrador de marketing existente para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Um usuário relata um login VPN não autorizado de outro país enquanto a conta ainda está ativa. Qual ação segue melhor o procedimento de comprometimento de conta?

A) Desativar a conta e revogar sessões e tokens ativos, depois redefinir as credenciais.

B) Redefinir a senha somente depois que o usuário retornar ao escritório fornecendo métricas quantitativas de risco para a diretoria

C) Aumentar os requisitos de complexidade de senha e continuar monitorando para atender a normas regulatórias obrigatórias de governança

D) Excluir a caixa de correio do usuário e o perfil VPN dentro dos limites formais de apetite a risco da organização

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização descobre repetidamente contas órfãs porque as notificações do RH sobre funcionários desligados são atrasadas. Qual controle no procedimento operacional padrão de offboarding previne melhor esse problema?

A) Exigir treinamento anual de conscientização de segurança para todos os funcionários fornecendo métricas quantitativas de risco para a diretoria

B) Impor expiração trimestral de senha para todas as contas de usuário para atender a normas regulatórias obrigatórias de governança

C) Executar simulações diárias de phishing para a equipe de segurança dentro dos limites formais de apetite a risco da organização

D) Integrar o desprovisionamento automatizado às mudanças de status do RH, para que a desativação da conta seja acionada quando o vínculo terminar.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Criar a conta apenas com acesso padrão e adicionar acesso a finanças após uma solicitação formal autorizada ser aprovada.

Procedimentos de onboarding exigem autorização verificada e provisionamento baseado em função, com privilégio mínimo. Uma solicitação verbal não é suficiente para acesso sensível. O service desk deve criar apenas a conta padrão aprovada e depois exigir solicitação formal e aprovação antes de conceder acesso a finanças. Contas compartilhadas e envio de credenciais para e-mail pessoal violam a política de segurança.

Questão 2: Alternativa A — Desativar a conta e revogar sessões e tokens ativos.

A primeira prioridade no offboarding é interromper o acesso. Desativar a conta e revogar sessões/tokens ativos imediatamente impede que o ex-funcionário use credenciais existentes. Excluir dados ou transferir a caixa de correio antes de desativar pode criar risco ou destruir evidências. Apenas redefinir a senha pode não encerrar sessões já ativas.

Questão 3: Alternativa B — Conta órfã

Uma conta órfã é uma conta ativa que não tem mais proprietário válido ou necessidade de negócio, frequentemente porque o offboarding foi incompleto. Ela deve ser revisada, desativada e removida de acordo com os requisitos de retenção. Contas de serviço, compartilhadas e privilegiadas têm definições e controles diferentes.

Questão 4: Alternativa D — Instruir o usuário a não interagir com a mensagem, preservar o e-mail e escalá-lo para a equipe de segurança.

O procedimento de resposta a phishing exige conter o relato e escalá-lo para a equipe de segurança para análise. O usuário não deve interagir com a mensagem, e o e-mail original deve ser preservado para investigação. Encaminhar em massa pode espalhar o phishing, excluir destrói evidências, e redefinir senha só é necessário se credenciais foram inseridas.

Questão 5: Alternativa A — Seguir o processo aprovado de verificação de identidade; se a verificação falhar, não redefinir e escalar a solicitação.

Procedimentos de redefinição de senha exigem verificação forte de identidade antes de alterar credenciais. Conhecer o nome de usuário ou o nome do gerente não é suficiente. Se o solicitante não conseguir satisfazer a verificação, o agente deve recusar a redefinição e escalar. Enviar credenciais para e-mail pessoal, pedir a senha antiga ou desativar MFA enfraquece a segurança.

Questão 6: Alternativa C — Apagar remotamente o notebook e rastrear a devolução do ativo por meio da lista de verificação de offboarding.

O offboarding inclui coletar ou apagar remotamente ativos da empresa. Um notebook ausente pode expor dados armazenados localmente, credenciais em cache ou configurações de VPN. Apagar remotamente e rastrear o ativo aborda diretamente esse risco. Alterações de senha em todo o domínio, exclusão de caixa de correio e desativação de token MFA não controlam o endpoint ausente.

Questão 7: Alternativa D — Colocar a mensagem em quarentena em todas as caixas de correio e bloquear o remetente e a URL.

A contenção visa impedir que a ameaça se espalhe ou seja acessada. Colocar a mensagem em quarentena em todas as caixas de correio e bloquear remetente/URL impede novos cliques e entregas. Alertas e encaminhamento são úteis depois, mas não contêm o e-mail malicioso. Redefinições em massa de senha não são indicadas a menos que credenciais tenham sido comprometidas.

Questão 8: Alternativa B — Negar a solicitação e provisionar apenas o acesso padrão da função de marketing; exigir justificativa e aprovação separadas para qualquer acesso privilegiado.

O onboarding deve seguir o privilégio mínimo e o controle de acesso baseado em função. Acesso de administrador de domínio não se justifica por projetos futuros e não deve ser concedido por padrão. O administrador deve negar a solicitação, provisionar a função padrão e exigir uma solicitação separada aprovada para acesso privilegiado. Concessões temporárias, apenas MFA ou credenciais administrativas compartilhadas não corrigem privilégio excessivo.

Questão 9: Alternativa A — Desativar a conta e revogar sessões e tokens ativos, depois redefinir as credenciais.

Quando uma conta é suspeita de comprometimento, o procedimento deve conter o incidente primeiro. Desativar a conta e revogar sessões/tokens ativos impede que o atacante continue usando o acesso existente. A redefinição de credenciais vem após a contenção. Esperar, apenas aumentar a complexidade ou excluir caixa de correio/perfil VPN não encerra prontamente o acesso não autorizado.

Questão 10: Alternativa D — Integrar o desprovisionamento automatizado às mudanças de status do RH, para que a desativação da conta seja acionada quando o vínculo terminar.

Contas órfãs geralmente resultam de offboarding atrasado ou não realizado. Automatizar o desprovisionamento com base em mudanças de status do RH reduz atrasos humanos e garante que as contas sejam desativadas quando o vínculo terminar. Treinamento de conscientização, expiração de senha e simulações de phishing não previnem diretamente contas órfãs.